

SOC INVESTIGATION REPORT

Phishing Email Investigation & Response

Client: MediSure Health Network

Prepared by: Adebisi Damilola (Soc Analyst)

Cybersecurity Internship Programme, 2026

Table of Contents

1. Executive Summary
2. Introduction
 - i. Company Background
 - ii. Objectives of This Investigation
3. Methodology
4. Technology Stack
5. Key Findings
 - i. Header Analysis
 - ii. Indicators of Compromise
 - iii. Threat Intelligence
 - iv. URL and Attachment Review
 - v. Log Correlation (Splunk)
 - vi. Triage Verdict
6. Response & Mitigation-Incident Response Playbook
 - i. Planning
 - ii. Detection
 - iii. Analysis
 - iv. Containment & Eradication
 - v. Recovery
 - vi. Lessons Learned
 - vii. Governance
7. References

1. Executive Summary

A phishing email impersonating Microsoft's account security team was sent to a MediSure staff member, warning of a fake suspicious sign-in and directing them to a credential-harvesting link. The email failed all sender authentication checks (SPF, DKIM, DMARC), and threat intelligence confirmed it was part of a phishing kit reused against other organizations since 2022, not an attack built specifically for MediSure. Log correlation across proxy, firewall, and authentication systems confirmed three staff accounts interacted with the malicious infrastructure, including one failed login attempt from a foreign IP. The incident is classified as a true positive spear-phishing / credential-harvesting attempt and was contained with no confirmed data breach. The root cause was a missing DMARC enforcement policy, which is the primary recommendation addressed in this report.

2. Introduction

i. Company Background

MediSure Health Network is an integrated healthcare network founded in 2003, encompassing hospitals, clinics, specialty centers, and a telemedicine platform. It serves patients across private insurance, Medicare, Medicaid, and direct-pay channels, and collaborates with universities and pharmaceutical partners on research and AI-powered diagnostics. Its centralized EHR backbone, in place since 2012, connects all facilities under one data environment.

ii. Objectives of This Investigation

- Determine whether the reported email is genuinely malicious or a false positive.
- Identify and document all indicators of compromise (IOCs) associated with the email.
- Assess whether any MediSure staff interacted with the malicious infrastructure.
- Establish the root cause that allowed the email to reach an employee inbox.
- Produce a response and mitigation plan to contain the current incident and reduce recurrence.

3. Methodology

This investigation followed a structured SOC workflow, moving from raw evidence to a corroborated verdict:

- Header analysis: the email's raw source was examined for sender authenticity, relay path, and header inconsistencies using MXToolbox.
- Indicator extraction: IP addresses, domains, and reply-to addresses were catalogued as IOCs directly from the header and body content.
- Threat intelligence corroboration: each IOC was independently checked against VirusTotal, AlienVault OTX, and AbuseIPDB to establish reputation and history, rather than relying on any single source.
- Log correlation: the extracted IOCs were searched against MediSure's proxy, firewall, and authentication logs in Splunk to determine actual staff interaction with the campaign.
- Triage and classification: findings were combined into a single verdict (true/false positive) and attack classification (mass phishing, spear-phishing, or BEC).
- Response planning: containment, recovery, and lessons-learned actions were defined based on the specific accounts and infrastructure identified during analysis.

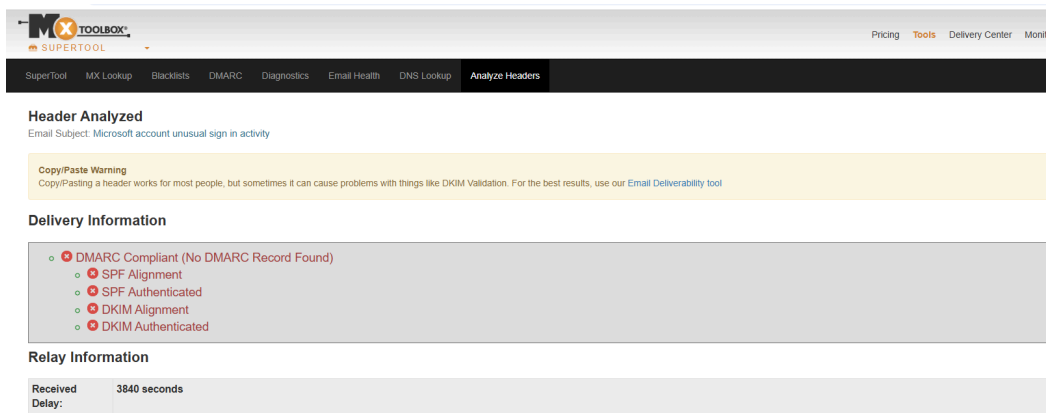
4. Technology Stack

Tool	Purpose
MXToolbox	Email header analysis; SPF, DKIM, DMARC validation
VirusTotal	Domain, IP, and URL reputation scanning across security vendors
AlienVault OTX	Passive DNS, WHOIS, and indicator threat intelligence
AbuseIPDB	Historical abuse reports for IP addresses
Splunk (Free)	SIEM log ingestion and correlation across proxy, firewall, and auth logs

5. Key Findings

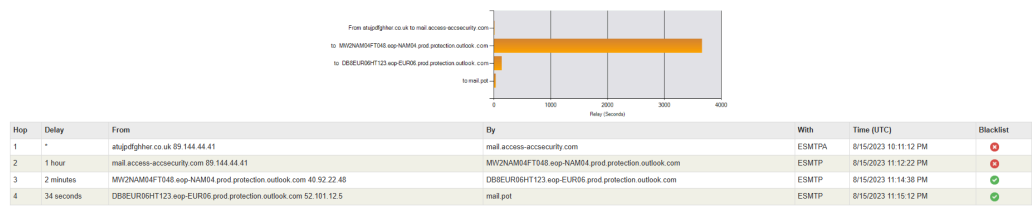
i. Header Analysis

Header analysis was run through MXToolbox against the raw email source. The domain access-accsecurity.com has no DMARC record published, and the message failed both SPF and DKIM, meaning nothing about the sending path was authenticated.



MXToolbox delivery information- DMARC not published, SPF and DKIM both failed.

The relay path shows the message originated from attacker-controlled infrastructure before touching Microsoft's legitimate relay network two hops later.



Relay/hop path- early hops from attacker infrastructure, later hops from Microsoft's legitimate mail protection network.

Full header values below, including Return-Path and the Authentication-Results line (SPF fail, DKIM none, DMARC permerror). The Reply-To address is a personal Gmail account, inconsistent with the claimed Microsoft sender.

SPF and DKIM Information

dmarc:access-accsecurity.com

Hide

Solve Email Delivery Problems

Test	Result
DMARC Record Published	No DMARC Record found

Reported by b.gtd-servers.net on 7/13/2026 at 8:24:21 PM (UTC 0) just for you

Transcript

spf:access-accsecurity.com:89.144.44.41

Show

Solve Email Delivery Problems

DKIM Signature Error:

No DKIM-Signature header found - [more info](#)

DKIM Signature Error:

There must be at least one aligned DKIM-Signature for the message to be considered aligned. - [more info](#)

Headers Found

Header Name	Header Value
Return-Path	<no-reply@access-accsecurity.com>
Authentication-Results	mail pot, spf=fail (mail pot domain of access-accsecurity.com does not designate 89.144.44.41 as permitted sender) smtp mailfrom=no-reply@access-accsecurity.com, dkim=none (no signature), dmarc=permerror (no valid record) header from=access-accsecurity.com

Full header values-Return-Path, Authentication-Results, and related fields.

ii. Indicators of Compromise

Indicator	Value
Sending IP	89.144.44.41
Sending domain	access-accsecurity.com
Reply-To (attacker)	solutionteamrecognizd03@gmail.com
Malicious link	sign.in
Tracking pixel domain	thebandalisty.com
Claimed sign-in IP (in email body, unverified)	103.225.77.255

Microsoft account unusual sign in activity

MT

Microsoft account team<no-reply@access-accsecurity.com>

To: employee@medisurehealthnetwork.com

Wed 8/16/2023 12:15 AM

We detected something unusual about a recent sign-in to the Microsoft account

Sign-in details:

- Country/region: Russia
- IP address: 103.225.77.255
- Date: Wed, 16 Aug 2023 00:05:41 GMT
- Platform: Windows
- Browser: Chrome

If this was you, you can safely ignore this email. If not, we recommend that you [secure your account](#) immediately.

The email was received-spoofed Microsoft sender, fabricated sign-in alert, embedded link.

iii. Threat Intelligence

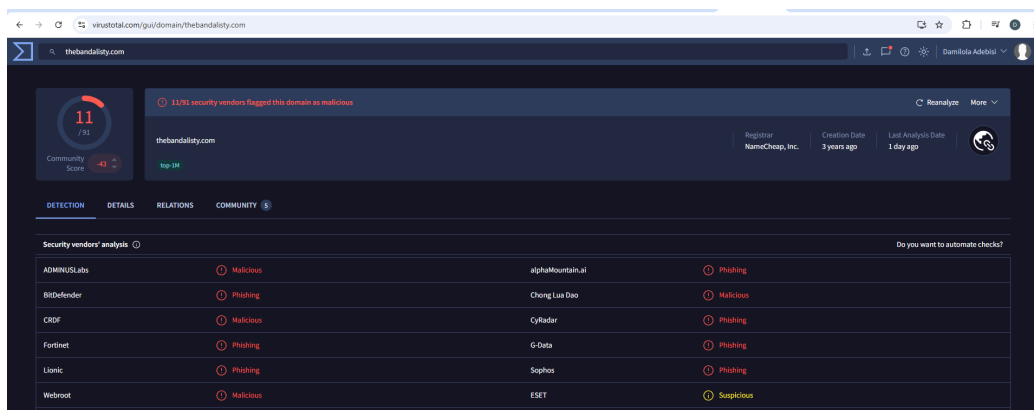
Each indicator was checked independently across VirusTotal, AbuseIPDB and OTX rather than assumed guilty by association.

thebandalisty.com (tracking pixel domain)

This is the domain silently pinged by the hidden tracking pixel in the email's HTML body, used to confirm the message was opened. VirusTotal flags it as malicious, with 11 of 91 security vendors detecting it several tagging it specifically as phishing (BitDefender, Fortinet, Lionic, Sophos, alphaMountain) and others as outright malicious (ADMINUSLabs, CRDF, Webroot, Chong Lua Dao). The domain sits in VirusTotal's top-1M ranked list, meaning it is an actively indexed, live domain rather than an obscure one-off.

```
<html>
<body>
  <p><strong>We detected something unusual about a recent sign-in to the Microsoft account</strong></p>
  <p><strong>Sign in details:</strong></p>
  <ul>
    <li><strong>Country/region:</strong> Russia</li>
    <li><strong>IP address:</strong> 103.225.77.255</li>
    <li><strong>Date:</strong> Wed, 16 Aug 2023 00:05:41 GMT</li>
    <li><strong>Platform:</strong> Windows</li>
    <li><strong>Browser:</strong> Chrome</li>
  </ul>
  <p>If this was you, you can safely ignore this email. If not, we recommend that you <a href="https://sign.in/">secure your account</a> immediately.</p>
  <!-- Tracking pixel (defanged for safety in this dataset) -->
  <!-- Original: 
  
</body>
</html>
```

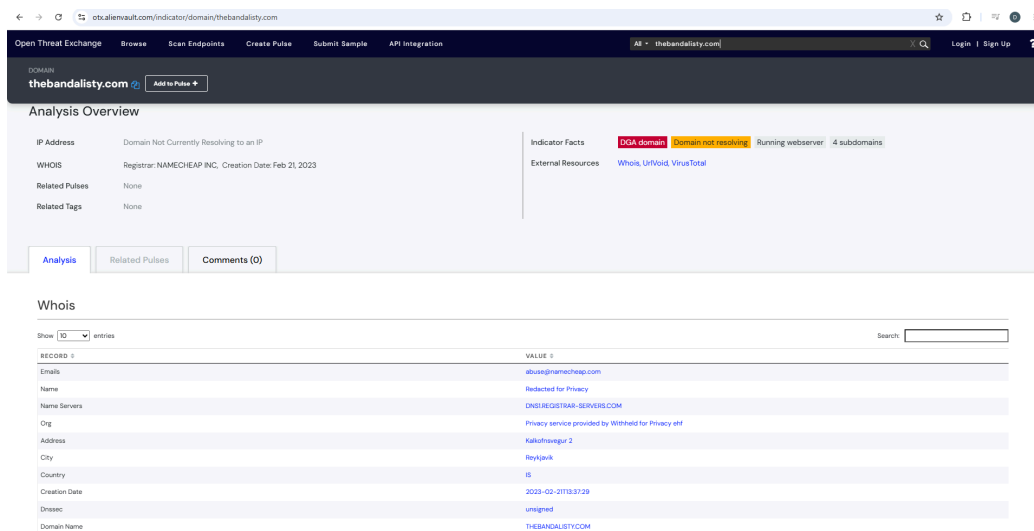
Raw HTML source of the email, showing the embedded tracking pixel referencing thebandalisty.com.



Security vendors' analysis	Result
ADMINUSLabs	Malicious
BitDefender	Phishing
CRDF	Malicious
Fortinet	Phishing
Lionic	Phishing
Webroot	Malicious
alphaMountain.ai	Phishing
Chong Lua Dao	Malicious
CyRadat	Phishing
G-Dat	Phishing
Sophos	Phishing
ESET	Suspicious

VirusTotal-thebandalisty.com scan result (red 11/91 detections details).

OTX corroborates this: The domain is registered through NameCheap, tagged as a DGA (domain generation algorithm) domain, and is currently not resolving to an IP. This pattern registered, weaponized briefly, then dropped is typical of disposable phishing infrastructure that gets cycled out once reported or blacklisted.



Analysis Overview

IP Address: Domain Not Currently Resolving to an IP

WHOIS: Registrar: NAMECHEAP INC, Creation Date: Feb 21, 2023

Related Pulses: None

Related Tags: None

Whois

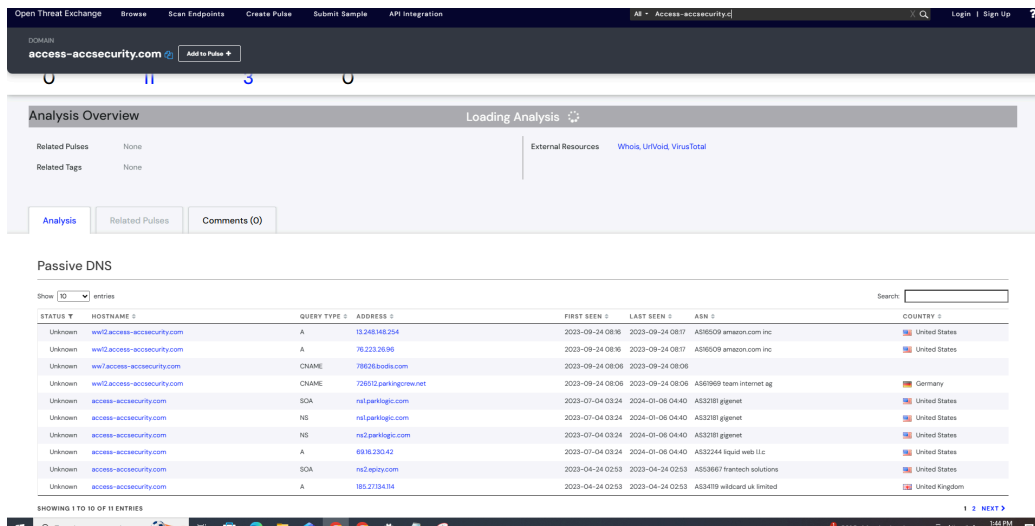
Show 10 entries

RECORD	VALUE
Emails	abuse@namecheap.com
Name	Redacted for Privacy
Name Servers	DNS1.REGISTRAR-SERVERS.COM
Org	Privacy service provided by Withheld for Privacy ehf
Address	Kaloftheggar 2
City	Reykjavik
Country	IS
Creation Date	2023-02-21T18:31:28
Names	unregistered
Domain Name	THEBANDALISTY.COM

OTX-thebandalisty.com WHOIS and indicator tags (registrar: NameCheap, tagged as a DGA domain, not currently resolving).

access-accsecurity.com (sending domain)

The domain used to send the email itself, checked separately for reputation and passive DNS history.



Analysis Overview

Related Pulses: None

Related Tags: None

External Resources: Whois, Unifind, VirusTotal

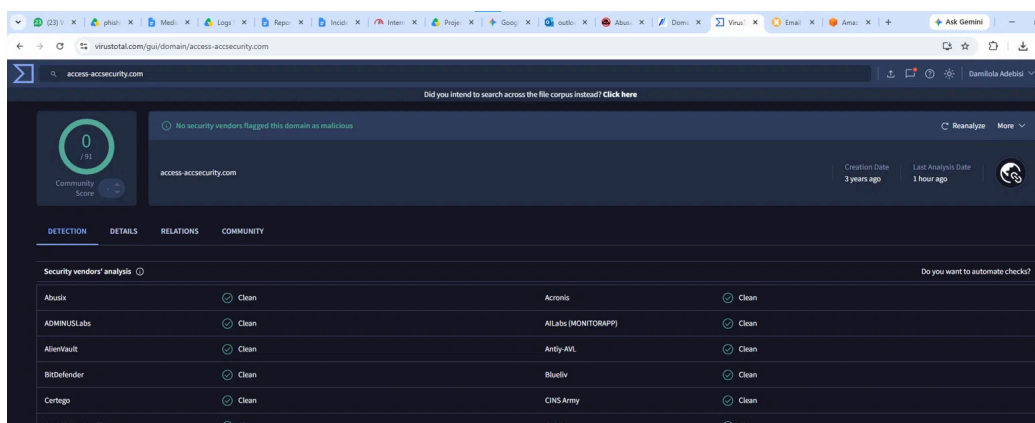
Passive DNS

Show 10 entries

STATUS	HOSTNAME	QUERY TYPE	ADDRESS	FIRST SEEN	LAST SEEN	ASN	COUNTRY
Unknown	www2.access-accsecurity.com	A	13.248.148.204	2023-09-24 08:16	2023-09-24 08:17	AS16509 amazon.com inc	United States
Unknown	www2.access-accsecurity.com	A	76.223.26.96	2023-09-24 08:16	2023-09-24 08:17	AS16509 amazon.com inc	United States
Unknown	www2.access-accsecurity.com	CHAME	78626.bodix.com	2023-09-24 08:06	2023-09-24 08:08		
Unknown	www2.access-accsecurity.com	CHAME	726072.parkingcrew.net	2023-09-24 08:06	2023-09-24 08:08	AS61969 team internet ag	Germany
Unknown	access-accsecurity.com	SOA	ns1.parklogic.com	2023-07-04 03:24	2024-01-06 04:40	AS32181 giganet	United States
Unknown	access-accsecurity.com	NS	ns1.parklogic.com	2023-07-04 03:24	2024-01-06 04:40	AS32181 giganet	United States
Unknown	access-accsecurity.com	NS	ns2.parklogic.com	2023-07-04 03:24	2024-01-06 04:40	AS32181 giganet	United States
Unknown	access-accsecurity.com	A	69.16.230.42	2023-07-04 03:24	2024-01-06 04:40	AS32244 liquid web llc	United States
Unknown	access-accsecurity.com	SOA	ns2.epix.com	2023-04-24 02:53	2023-04-24 02:53	AS53667 frantech solutions	United States
Unknown	access-accsecurity.com	A	185.2134.134	2023-04-24 02:53	2023-04-24 02:53	AS34119 wildcard uk limited	United Kingdom

SHOWING 1 TO 10 OF 11 ENTRIES

OTX page showing passive DNS table for access-accsecurity.com



Did you intend to search across the file corpus instead? [Click here](#)

Community Score: 0 / 91

Creation Date: 3 years ago

Last Analysis Date: 1 hour ago

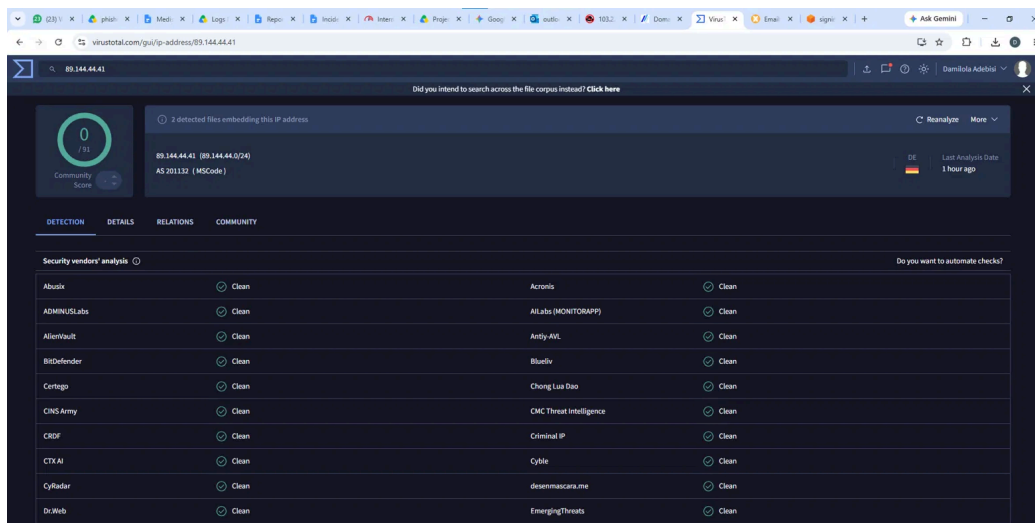
Security vendors' analysis

Vendor	Result	Vendor	Result
Abusix	Clean	Acronis	Clean
ADMINUSLabs	Clean	ALi Labs (MONITORAPP)	Clean
AlienVault	Clean	Antiy-AVL	Clean
BitDefender	Clean	BlueViv	Clean
Cortego	Clean	CNS Army	Clean
Cyber Threat Intelligence	Clean	Cybereason	Clean

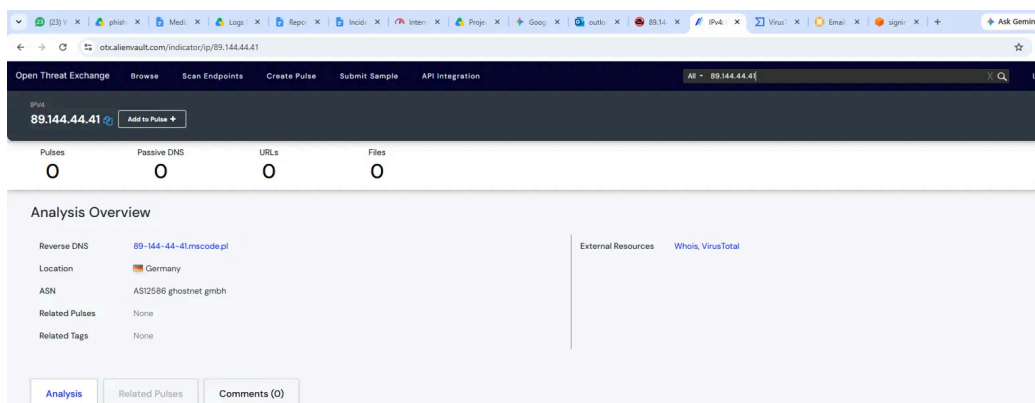
VirusTotal-access-accsecurity.com scan result.

89.144.44.41 (sending IP) and sign.in (malicious link)

The sending IP resolves to hosting infrastructure in Germany rather than any legitimate Microsoft range. The sign.in link, the actual destination behind “secure your account” carries a malicious flag and a spam-URL tag from VirusTotal.



VirusTotal Threat intelligence lookup-sending IP 89.144.44.41.



No Additional Analysis Available

OTX page for 89.144.44.41 (Germany, ghostnet gmbh)

103.225.77.255 (claimed sign-in IP, from the email body)

This is the IP the email itself claims the “suspicious sign-in” came from. It never appears in MediSure's actual traffic logs; it is bait text written into the email to make the alert look convincing. AbuseIPDB shows a long report history against it, with multiple reporters independently describing this exact same template (Russia, “secure your account,” Microsoft impersonation), confirming this is a reused phishing kit rather than something built specifically for MediSure.

AbuseIPDB » 103.225.77.255

Check an IP Address, Domain Name, Subnet, or ASN
e.g. 105.127.11.118, microsoft.com, 5.188.10.0/24, or AS15169

103.225.77.255

103.225.77.255 was found in our database!
This IP was reported 41 times. Confidence of Abuse is 0%.

0%

ISP: Adsizzler Media Pvt Ltd
Usage Type: Unknown
ASN: Unknown
Domain Name: adsizzler.com
Country: India
City: Mumbai, Maharashtra

IP info including ISP, Usage Type, and Location provided by IPinfo. Updated weekly.

REPORT 103.225.77.255 WHOIS 103.225.77.255

IP Abuse Reports for 103.225.77.255:
This IP address has been reported a total of 41 times from 17 distinct sources. 103.225.77.255 was first reported on March 11th 2022, and the most recent report was 2 years ago.
Old Reports: The most recent abuse report for this IP address is from 2 years ago. It is possible that this IP is no longer involved in abusive activities.

Reporter	IoA Timestamp (UTC)	Comment	Categories
Anonymous	2024-04-22 08:52:00 (2 years ago)	Got Email with telling try to access from Russia and this was from India. Some companies use this ip ...	Web Spam, Email Spam
Red Lee	2023-10-24 03:17:52 (2 years ago)	Every day they try to get into my Microsoft account.	Phishing
areento	2023-10-20 23:31:03 (2 years ago)	spam	Web Spam, Email Spam
Grepco	2023-10-15 18:17:39 (2 years ago)	Same as everyone else. Received fraudulent MS email meant to scare. Ignore. Junk SPAM.	Email Spam, Spoofing
Anonymous	2023-10-08 17:35:09 (2 years ago)	Spoofing Microsoft account team.	Email Spam, Spoofing
Red Lee	2023-09-18 01:40:40 (2 years ago)	Reported by Microsoft, this IP invades my account day after day. and nothing is done to stop it.	Phishing
Anonymous	2023-08-24 16:44:10 (2 years ago)	PART OF AN ELABORATE SCAM TO MAKE YOU THINK THAT RUSSIA HAS HACKED YOUR MICROSOFT ACCOUNT ALSO BEEN ...	Phishing, Web Spam, Email Spam, Spoofing, Exploited Host
Ben.BSH	2023-08-20 08:37:01	Microsoft has notified me about "Unusual sign in activity"	Email Spam

AbuseIPDB summary page, "41 times reported," ISP Adsizzler

AbuseIPDB » 103.225.77.255

Check an IP Address, Domain Name, Subnet, or ASN
e.g. 105.127.11.118, microsoft.com, 5.188.10.0/24, or AS15169

103.225.77.255

103.225.77.255 was found in our database!
This IP was reported 41 times. Confidence of Abuse is 0%.

0%

ISP: Adsizzler Media Pvt Ltd
Usage Type: Unknown
ASN: Unknown
Domain Name: adsizzler.com
Country: India
City: Mumbai, Maharashtra

IP info including ISP, Usage Type, and Location provided by IPinfo. Updated weekly.

REPORT 103.225.77.255 WHOIS 103.225.77.255

IP Abuse Reports for 103.225.77.255:
This IP address has been reported a total of 41 times from 17 distinct sources. 103.225.77.255 was first reported on March 11th 2022, and the most recent report was 2 years ago.
Old Reports: The most recent abuse report for this IP address is from 2 years ago. It is possible that this IP is no longer involved in abusive activities.

Reporter	IoA Timestamp (UTC)	Comment	Categories
Anonymous	2024-04-22 08:52:00 (2 years ago)	Got Email with telling try to access from Russia and this was from India. Some companies use this ip ...	Web Spam, Email Spam
Red Lee	2023-10-24 03:17:52 (2 years ago)	Every day they try to get into my Microsoft account.	Phishing
areento	2023-10-20 23:31:03 (2 years ago)	spam	Web Spam, Email Spam
Grepco	2023-10-15 18:17:39 (2 years ago)	Same as everyone else. Received fraudulent MS email meant to scare. Ignore. Junk SPAM.	Email Spam, Spoofing
Anonymous	2023-10-08 17:35:09 (2 years ago)	Spoofing Microsoft account team.	Email Spam, Spoofing
Red Lee	2023-09-18 01:40:40 (2 years ago)	Reported by Microsoft, this IP invades my account day after day. and nothing is done to stop it.	Phishing
Anonymous	2023-08-24 16:44:10 (2 years ago)	PART OF AN ELABORATE SCAM TO MAKE YOU THINK THAT RUSSIA HAS HACKED YOUR MICROSOFT ACCOUNT ALSO BEEN ...	Phishing, Web Spam, Email Spam, Spoofing, Exploited Host
Ben.BSH	2023-08-20 08:37:01	Microsoft has notified me about "Unusual sign in activity"	Email Spam

AbuseIPDB scrolled-down report list (Red Lee, Grepco, etc. comments)

iv. URL and Attachment Review

No attachment was present in this email. The attack vector was link-based only: the visible “secure your account” text resolves to sign.in, and a hidden tracking pixel silently confirms the email was opened. The link itself was not visited manually; reputation was assessed through VirusTotal and OTX instead, in line with standard analysis safety practice.

The sign.in link, the actual destination behind 'secure your account' was flagged by 1 of 91 VirusTotal vendors and tagged as a spam URL. OTX shows the domain has a long legitimate registration history (since 2018) and is currently parked, meaning the single flag is a weak signal on its own, this may reflect a deliberately plausible-sounding domain choice for social engineering rather than confirmed malicious hosting."

Did you intend to search across the file corpus instead? [Click here](#)

1

/ 91

Community Score

1/91 security vendor flagged this domain as malicious

sign.in

Registrar: Dynadot, LLC | Creation Date: 7 years ago | Last Analysis Date: 1 day ago

business

business and economy

SPAM URLs

top-1M

DETECTION

DETAILS

RELATIONS

COMMUNITY

Security vendors' analysis

Do you want to automate checks?

Webroot	Malicious	alphaMountain.ai	Suspicious
Abusix	Clean	Acronis	Clean
ADMINUSLabs	Clean	AlLabs (MONITORAPP)	Clean
AlienVault	Clean	Antiy-AVL	Clean
BitDefender	Clean	Blueliv	Clean
Cortego	Clean	CINS Army	Clean
CMC Threat Intelligence	Clean	CRDF	Clean

VirusTotal page for sign.in, red "1/91", Webroot malicious

Open Threat Exchange

Browse

Scan Endpoints

Create Pulse

Submit Sample

API Integration

All - sign.in

Login

Sign Up

DOMAIN

sign.in

Add to Pulse

Pulses

Passive DNS

URLs

Files

0

185

6

0

Analysis Overview

IP Address

64.190.63.222

Location

Germany

ASN

AS47846 sedo

Nameservers

ns2.sedoparking.com, ns1.sedoparking.com

WHOIS

Registrar: Key-Systems GmbH (R48-AFIN), Creation Date: Unknown

Related Pulses

None

Related Tags

None

Indicator Facts

Parked domain, Running webserver, 64 subdomains, SPF record

External Resources

Whois, UrVoid, VirusTotal

Analysis

Related Pulses

Comments (0)

Whois

Show

10

entries

Search:

RECORD	VALUE
Emails	blake.ramsdell@brutesquadlabs.com
Name	Blake Ramsdell
Name Servers	NS1.DREAMHOST.COM
Org	Brute Squad Labs, Inc.

Open Threat Exchange Browse Scan Endpoints Create Pulse Submit Sample API Integration All sign.in X Login Sign Up ?

DOMAIN
sign.in Add to Pulse +

Whois

Show 10 entries Search

RECORD	VALUE
Emails	blake.ramsdell@brutesquadlabs.com
Name	Blake Ramsdell
Name Servers	NS1DREAMHOST.COM
Org	Brute Squad Labs, Inc.
City	Sammamish
Country	US
Dnssec	Unsigned
Domain Name	SIGN.IN
Emails	blake.ramsdell@sign.in
Expiration Date	2018-02-19T06:30:30

SHOWING 1 TO 10 OF 15 ENTRIES 1 2 NEXT

Passive DNS

Show 10 entries Search

STATUS	HOSTNAME	QUERY TYPE	ADDRESS	FIRST SEEN	LAST SEEN	ASN	COUNTRY
Unknown	powerful123movies.without.sign.in	A	64.190.63.222	2026-07-17 10:12	2026-07-17 10:12	AS47846 sedo	Germany
Unknown	powerful123movies.without.sign.in	NS	ns2.sedoparking.com	2026-07-17 10:12	2026-07-17 10:12	AS47846 sedo	Germany
Unknown	powerful123movies.without.sign.in	NS	ns1.sedoparking.com	2026-07-17 10:12	2026-07-17 10:12	AS47846 sedo	Germany
Unknown	powerful123movies.without.sign.in	SOA	ns1.sedoparking.com	2026-07-17 10:12	2026-07-17 10:12	AS47846 sedo	Germany
Unknown	!sign.in	A	64.190.63.222	2026-07-15 04:53	2026-07-15 04:53	AS47846 sedo	Germany
Unknown	!sign.in	NS	ns2.sedoparking.com	2026-07-15 04:53	2026-07-15 04:53	AS47846 sedo	Germany

v. Log Correlation (Splunk)

The IOCs above were checked against MediSure's proxy, firewall, and auth logs (index=medisure_logs, 324 events) to determine whether anyone actually interacted with this campaign. The reference query set used is shown below.

drive.google.com/drive/folders/1y8V4MMec2P6BIZUhpB3nXv8D8CWH92

splunk_phishing_queries_mediure.txt Open with Google Docs

Page 1 / 1 100% Comment

- 1. Find users who clicked on phishing domains (proxy logs)
Source=(uploaded log .csv) log_type=proxy
(url_domain="sign.in" OR url_domain="access-accesecurity.com")
| stats count by user, src_ip, url_domain
- 2. Detect outbound connections to malicious IPs (firewall logs)
Source=(uploaded log .csv) log_type=firewall
(dest_ip="89.144.44.41" OR dest_ip="103.225.77.255")
| stats count by src_ip, dest_ip
- 3. Spot suspicious logins from unusual geolocations (auth logs)
Source=(uploaded log .csv) log_type=auth
location="Russia"
| stats count by user, result, location
- 4. Count all phishing-related events by user (summary for report)
Source=(uploaded log .csv)
(url_domain="sign.in" OR url_domain="access-accesecurity.com" OR dest_ip="89.144.44.41" OR dest_ip="103.225.77.255" OR location="Russia")
| stats count by user

Reference SPL query set used for log correlation (proxy, firewall, auth, and combined summary queries).

splunk> Enterprise

New Search

1 source="medisure_phishing_combined_logs.csv" host="DESKTOP-ABKH647" index="medisure_logs" sourcetype="csv" log_type=proxy (url_domain="access-accsecurity.com" OR url_domain="sign.in")
 2 | stats count by user, src_ip, url_domain

Time range: All time

4 events (before 7/14/26 12:36:03.000 PM) No Event Sampling

Events Patterns **Statistics (4)** Visualization

Show: 20 Per Page Format Preview: On

user	src_ip	url_domain	count
alice@medisurehealthnetwork.com	10.1.5.23	access-accsecurity.com	1
alice@medisurehealthnetwork.com	10.1.5.23	sign.in	1
bob@medisurehealthnetwork.com	10.1.5.45	access-accsecurity.com	1
bob@medisurehealthnetwork.com	10.1.5.45	sign.in	1

Proxy logs-Alice and Bob both visited access-accsecurity.com and sign.in.

Firewall logs show outbound connections to 89.144.44.41 from Alice and Carol, and auth logs show a failed login attempt against Bob's account from a Russian IP shortly after-consistent with an attacker attempting to use a harvested credential.

User	Clicked link (proxy)	Contacted attacker IP (firewall)	Failed login, Russia (auth)
alice@medisurehealthnetwork.com	Yes	Yes	-
bob@medisurehealthnetwork.com	Yes	-	Yes
carol@medisurehealthnetwork.com	-	Yes (x2)	-

splunk> Enterprise

New Search

1 source="medisure_phishing_combined_logs.csv" log_type="firewall" (dest_ip="89.144.44.41" OR dest_ip="103.225.77.255")
 2 | stats count by src_ip, dest_ip

Time range: All time

3 events (before 7/14/26 3:01:28.000 PM) No Event Sampling

Events Patterns **Statistics (2)** Visualization

Show: 20 Per Page Format Preview: On

src_ip	dest_ip	count
10.1.5.23	89.144.44.41	1
10.1.5.89	89.144.44.41	1

Additional log correlation supporting the firewall/auth findings above.

New Search

```
1 source="medisure_phishing_combined_logs.csv" log.type="auth" location="Russia"
2 | stats count by user, result, location
```

Time range: All time

1 event (before 7/14/26 3:31:35.000 PM) No Event Sampling

user	result	location	count
bob@medisurehealthnetwork.com	Failure	Russia	1

Splunk auth log query confirming Bob's failed login attempt from Russia.

Running the combined summary query (all indicators, grouped by user) returned Alice at 2 events and Bob at 3, with Carol absent from the total despite her confirmed firewall hits. This is a data quality gap, not a query error: firewall log entries in this dataset carry src_ip but not a user field, so user-based aggregation silently drops them. Carol's exposure only shows up by cross-referencing src_ip against the proxy/auth logs manually.

New Search

```
1 source="medisure_phishing_combined_logs.csv"
2 (url_domain="sign.in" OR url_domain="access-accesecurity.com" OR dest_ip="89.144.44.41" OR dest_ip="183.225.77.255" OR location="Russia")
3 | stats count by user
```

Time range: All time

8 events (before 7/14/26 3:32:16.000 PM) No Event Sampling

user	count
alice@medisurehealthnetwork.com	2
bob@medisurehealthnetwork.com	3

Combined summary query-Alice and Bob totals; Carol undercounted due to missing user field on firewall events.

vi. Triage Verdict

True positive. Sender authentication failed outright (no DMARC, SPF fail, DKIM none), the link and tracking-pixel domains carry independent malicious flags from VirusTotal and OTX, and three separate MediSure accounts show real interaction with the campaign in the logs. The reused “Russia sign-in” template and its history of abuse reports indicate this is a broader phishing kit rather than a MediSure-specific attack, which factors directly into the containment approach below (blocked by IOC, not by assuming a one-off).

- Classification: spear-phishing / credential harvesting, disguised as a Microsoft security alert.
- Confirmed interaction: Alice and Bob (clicked link); Alice and Carol (attacker IP contact); Bob (failed foreign login attempt).

Response & Mitigation-Incident Response Playbook

This playbook sets out MediSure's response structure for phishing incidents, following the NIST incident response lifecycle: Planning, Detection, Analysis, Containment & Eradication, Recovery, and Lessons Learned, with Governance operating as a continuous oversight layer across all five phases. Actions in this section reference the accounts and indicators confirmed in Section 5.

i. Planning

Planning covers what needs to be in place before a phishing email ever reaches an inbox.

- Core incident response team: Vulnerability manager, Threat manager, Risk manager, and an owner of the overall incident response process.
- Core team reviews and maintains incident response timelines, and publicises approved email communication tools and protocols so staff can distinguish real IT/SOC messages from impersonation attempts.
- High-value phishing targets identified in advance, company executives and Heads of Department with phishing indicators defined and reporting procedures established for all staff.
- Email security frameworks enforced at the gateway: SPF, DKIM, DMARC, and S/MIME, with anti-phishing software as an additional layer. This incident occurred specifically because DMARC enforcement was not in place for inbound spoof detection, closing this gap is the single highest-priority planning action arising from this case.
- Continuous security awareness training, including periodic phishing simulation campaigns to assess how employees actually respond, not just what they're told in training.
- Multi-factor authentication required for access to critical systems, with an M-of-N authorization model for the most sensitive actions, requiring a defined number of executives to jointly approve, rather than relying on any single individual.
- Ongoing threat intelligence review to stay abreast of emerging phishing tactics, with proactive blocking of traffic to and from known malicious IPs, domains, and URLs at the firewall.
- Execution policies configured to prevent users from running unauthorized executable files.

ii. Detection

Detection covers how a phishing attempt like this one gets identified going forward.

- Log monitoring and aggregation from all endpoints and network devices via a SIEM platform (Splunk, index=medisure_logs), with alert generation and automated incident response actions configured where possible.
- Other detection devices and tools: IDS, firewall, vulnerability scanners, antivirus, and spam filters.
- Employee identification and reporting of spoofed emails, emails linked to external or unknown URLs, and undeliverable/bounced email addresses, covered in the Employee Awareness Material accompanying this report.

- Notification channels from external users, law enforcement, and customers regarding suspicious email-related activity involving MediSure domains.
- Inspection of network packets for suspicious traffic, unknown IPs, or flagged IPs.
- Header, metadata, and URL inspection using tools such as MXToolbox, as demonstrated in this investigation.

iii. Analysis

Full technical analysis for this incident is documented in Section 5 of this report. In summary: sender authentication failed across SPF, DKIM, and DMARC; the tracking-pixel domain, sending domain, and malicious link were independently corroborated via VirusTotal, OTX, and AbuseIPDB; and log correlation confirmed interaction from three accounts (alice, bob, carol). The email was sent to a general employee mailbox rather than an executive or department-head account, and the identities behind alice, bob, and carol were not verified against MediSure's organizational directory as part of this investigation. On that basis, this attack is classified as spear-phishing / credential harvesting targeting specific MediSure staff accounts, rather than confirmed whale-phishing (which would require the targets to be verified executives or senior stakeholders) or untargeted mass phishing. Confirming the seniority of the affected accounts is recommended as a follow-up action, since it would refine this classification and may warrant escalated handling if any belong to high-value stakeholders.

iv. Containment & Eradication

Containment actions are scoped to the specific accounts and infrastructure confirmed during analysis, rather than applied organization-wide by default.

- Isolate the endpoints associated with 10.1.5.23 (alice) and 10.1.5.89 (carol), both of which showed outbound connections to attacker infrastructure at 89.144.44.41.
- Disable and force credential reset on alice's and bob's accounts, both of which interacted with the malicious access-accsecurity.com / sign.in links.
- Quarantine the phishing email sample across all mailboxes it was delivered to, preventing further clicks or forwarding.
- Block the sending domain (access-accsecurity.com), the sending IP (89.144.44.41), and the malicious link (sign.in) at the email gateway and firewall.
- Add the tracking-pixel domain (thebandalisty.com) and the claimed sign-in IP (103.225.77.255) to blocklists, given their independent malicious flags and history of reuse in similar campaigns elsewhere.

Conditional Escalation (pending role verification): *If alice, bob, or carol are confirmed as executives or department heads, add:*

- Audit mailboxes for unauthorized forwarding/delegate rules added during the compromise window.
- Review outbound emails from the accounts for fraudulent payment requests (BEC risk).
- Escalate to legal/executive leadership on a shortened reporting timeframe.

v. Recovery

- Terminate any malicious processes initiated by the compromised accounts (alice, bob, carol) and confirm no malicious processes or persistence remain on the isolated endpoints (10.1.5.23, 10.1.5.89) before reconnecting them to the network.
- Remove phishing links and the quarantined email sample from mail servers organization-wide.
- Coordinate with a third-party takedown service to identify and remove the malicious sending domain, tracking-pixel domain, and related infrastructure from the internet where MediSure does not have direct control over it.
- Confirm no unauthorized access succeeded: auth logs already show bob's login attempt from Russia resulted in a failure, which should be explicitly documented as a positive outcome rather than assumed.
- Reset passwords for all three affected accounts before restoring access, and require re-authentication with MFA.
- Test and confirm the eradication procedure before returning any isolated device to production use.

vi. Lessons Learned

The root cause of this incident was straightforward: access-accsecurity.com had no DMARC record published, so a spoofed “Microsoft account team” sender was never rejected or flagged before reaching an employee inbox. Two of three test accounts went on to click the embedded link.

- Configure and enforce DMARC (with a reject or quarantine policy, not just monitoring) across MediSure's mail environment, this single change would very likely have prevented this email from being delivered at all.
- Update detection tool signatures and blocklists with the IOCs confirmed in this investigation.
- Refresh employee security awareness training using this incident as a concrete example, given that two of three test accounts interacted with the malicious link, see the accompanying Employee Awareness Material.
- Feed this incident's findings back into the Planning phase to close the identified gap before the next review cycle.

vii. Governance

Governance is not a sequential phase but a continuous layer of ownership and oversight across all phases above.

- Managerial tasks assigned to key stakeholders to oversee each phase, SOC Lead for containment and eradication, IT Manager for recovery and restoration, Compliance/Privacy Officer for HIPAA breach-notification review given MediSure's PHI exposure risk, and Cybersecurity Lead for Lessons Learned action items.
- Defined timeframes within which reports at each phase are expected to be met.
- Compliance to organizational rules and regulatory obligations tracked throughout the response.
- Continuous monitoring and people management to confirm actions are actually being carried out, not just assigned.

7. References

- MXToolbox: Email Header Analyzer and DMARC/SPF/DKIM Lookup Tool. mxtoolbox.com
- VirusTotal: Domain, IP, and URL Reputation Scanning. virustotal.com
- AlienVault OTX (Open Threat Exchange): Threat Intelligence Platform. otx.alienvault.com
- AbuseIPDB: IP Address Abuse Reporting Database. abuseipdb.com
- Splunk Free: SIEM and Log Analysis Platform. splunk.com
- NIST Computer Security Incident Handling Guide (SP 800-61): Incident response lifecycle framework.
- MediSure Health Network Phishing Investigation Project: Cybersecurity Internship Programme, 2026.